RPL318

Security Database

KEAMANAN BASIS DATA

Ganjil 2026 – 2027



PROGRAM STUDI
TEKNOLOGI REKAYASA
PERANGKAT LUNAK
POLIBATAM





User, privilege, role, least privilege MySQL

Tujuan Pembelajaran–TP2 :

Mahasiswa mampu:
mengidentifikasi dan menerapkan standar keamanan yang relevan untuk basis data relasional maupun non-relasional dalam pengelolaan dan perlindungan data organisasi.

Sub–Tujuan Pembelajaran–TP2.1 :

Mahasiswa mampu:
Mahasiswa mampu mengidentifikasi standar keamanan yang relevan untuk basis data relasional dan menerapkannya dalam pengelolaan keamanan data.

PROGRAM STUDI
TEKNOLOGI REKAYASA PERANGKAT LUNAK
POLIBATAM

Praktikum

Persiapan environtment

- Gunakan MySQL pada **PC Labkom untuk Latihan Individu di LabKom, Gunakan PC Labkom/Device pribadi mahasiswa untuk Latihan tim.**
- Untuk menghindari hal yang tidak terduga, dapat menggunakan DB terpisah dari DB-PBL
- Akan ada empat akun digunakan:

Account	Fungsi	Akses yang Dibutuhkan	Akses yang Dilarang
p4_reader	Auditor/read-only	SELECT	INSERT, UPDATE, DELETE
p4_operator	Operator transaksi	SELECT, INSERT, UPDATE	DELETE, DDL, GRANT
laravel_app	Runtime Laravel	minimum sesuai fitur	root/admin/DDL/GRANT
p4_admin	Admin lab	kelola account/privilege	digunakan hanya untuk administrasi

Buatkan DB (Latihan individu)

```
CREATE DATABASE IF NOT EXISTS kb_p4;
USE kb_p4;

CREATE TABLE customers (
    customer_id INT PRIMARY KEY AUTO_INCREMENT,
    name VARCHAR(100) NOT NULL,
    email VARCHAR(150) NOT NULL
);

CREATE TABLE transactions (
    transaction_id INT PRIMARY KEY AUTO_INCREMENT,
    customer_id INT NOT NULL,
    amount DECIMAL(12,2) NOT NULL,
    status VARCHAR(30) NOT NULL,
    FOREIGN KEY (customer_id) REFERENCES customers(customer_id)
);

INSERT INTO customers(name,email)
VALUES ('Ayu','ayu@example.test'),
       ('Bima','bima@example.test');

INSERT INTO transactions(customer_id,amount,status)
VALUES (1,150000.00,'PAID'),
       (2,275000.00,'PENDING');
```

BUATKAN BEBERAPA MYSQL USER

```
CREATE USER 'p4_reader'@'localhost'
IDENTIFIED BY 'P4Reader!2026';

CREATE USER 'p4_operator'@'localhost'
IDENTIFIED BY 'P4Operator!2026';

CREATE USER 'laravel_app'@'localhost'
IDENTIFIED BY 'LaravelLab!2026';
```

VERIFIKASI AKUN TERSEBUT

```
SELECT User, Host FROM mysql.user WHERE
User IN
('p4_reader','p4_operator','laravel_app');
```

BUATKAN ROLE

```
CREATE ROLE 'role_p4_readonly';

CREATE ROLE 'role_p4_operator';
```

VERIFIKASI ROLE (JIKA MENGGUNAKAN MYSQL)

```
SELECT User, Host, account_locked FROM
mysql.user WHERE User LIKE 'role_p4_%';
```

BERIKAN PIVILEGE

```
GRANT SELECT
ON kb_p4.*
TO 'role_p4_readonly';
```

```
GRANT SELECT, INSERT, UPDATE
ON kb_p4.*
TO 'role_p4_operator';
```

TAMBAHKAN USER KE ROLE DAN TETAPKAN DEFAULT ROLE

```
GRANT 'role_p4_readonly' TO
'p4_reader'@'localhost';
```

```
GRANT 'role_p4_operator' TO
'p4_operator'@'localhost';
```

```
SET DEFAULT ROLE 'role_p4_readonly' TO
'p4_reader'@'localhost';
```

```
SET DEFAULT ROLE 'role_p4_operator' TO
'p4_operator'@'localhost';
```

Uji coba SHOW GRANTS

```
SHOW GRANTS FOR 'p4_reader'@'localhost';
SHOW GRANTS FOR 'p4_operator'@'localhost';

SHOW GRANTS FOR 'role_p4_readonly';
SHOW GRANTS FOR 'role_p4_operator';
```

Hasil tabel akan seperti berikut:

Principal	Role/Privilege	Object	Interpretasi
p4_reader	role_p4_readonly	-	Mewarisi akses read-only
p4_operator	role_p4_operator	-	Mewarisi SELECT/INSERT/UPDATE
role_p4_readonly	SELECT	kb_p4.*	Tidak memiliki write/delete
role_p4_operator	SELECT, INSERT, UPDATE	kb_p4.*	Tidak memiliki DELETE

LAKUKAN PENGUJIAN PRIVILEGE

```
mysql -u p4_reader -p

mysql -u p4_operator -p
```

LAKUKAN PERPINDAHAN AKUN

```
SELECT USER() AS login_identity,
       CURRENT_USER() AS authenticated_account;

USE kb_p4;
```

PENGUJIAN SELECT

```
USE kb_p4;


SELECT * FROM customers;
SELECT * FROM transactions;
```

Hasil yang diharapkan: kedua SELECT berhasil karena role read-only memiliki privilege SELECT pada kb_p4.*

Kemudian coba dengan login pada p4_operator, lakukan pengujian Select

PENGUJIAN INSERT SEBAGAI P4_OPERATOR

```
INSERT INTO customers(name,email)
VALUES ('Citra','citra@example.test');


SELECT * FROM customers
ORDER BY customer_id;
```

Hasil yang diharapkan: INSERT berhasil karena p4_operator mewarisi privilege INSERT

PENGUJIAN UPDATE SEBAGAI P4_OPERATOR

```
UPDATE customers
SET email = 'citra.updated@example.test'
WHERE name = 'Citra';
```

```
SELECT customer_id,name,email
FROM customers
WHERE name = 'Citra’;
```

Hasil yang diharapkan: UPDATE berhasil. Evidence harus memperlihatkan perubahan nilai setelah UPDATE.

PENGUJIAN DELETE SEBAGAI P4_OPERATOR

```
DELETE FROM customers
WHERE name = 'Citra’;
```

Hasil yang diharapkan: MySQL menolak operasi dengan pesan akses/command denied. Dalam desain role_p4_operator, DELETE sengaja tidak diberikan. Karena itu, pengujian DELETE merupakan salah satu forbidden operation.

Penguji operasi yang forbidden

p4_reader mencoba INSERT

```
INSERT INTO customers(name,email)
VALUES
('Unauthorized','blocked@example.test’);
```

p4_reader mencoba UPDATE

```
UPDATE customers
SET email='changed@example.test'
WHERE customer_id=1;
```

p4_operator mencoba DDL

```
CREATE TABLE secret_test (
    id INT PRIMARY KEY
);
```

p4_operator mencoba GRANT

```
GRANT SELECT ON kb_p4.* TO
'p4_reader'@'localhost';
```

Perubahan hak akses / revoke

SEBAGAI ADMIN, CABUT OPERASI UPDATE DARI ROLE OPERATOR

REVOKE UPDATE

ON kb_p4.*

FROM 'role_p4_operator’;

Periksa kembali:

SHOW GRANTS FOR 'role_p4_operator';

UJI UPDATE SEBAGAI P4_OPERATOR

UPDATE customers

SET email='should.fail@example.test'

WHERE customer_id=1;

Expected: UPDATE sekarang gagal.

Namun SELECT dan INSERT masih seharusnya bekerja:

SELECT * FROM customers;

INSERT INTO customers(name,email)

VALUES ('Dedi','dedi@example.test');

Tetap Gunakan DB Individu (Latihan tim)

Lakukan menghubungkan API dengan MySQL. Privilege-nya harus ditentukan dari operasi database yang benar-benar dilakukan aplikasi.

Fitur/Endpoint	Table	SELECT	INSERT	UPDATE	DELETE	Catatan
Login/profile	users	Ya	Tidak/Ya*	Ya*	Tidak	Sesuaikan desain aplikasi
Daftar transaksi	transactions	Ya	Tidak	Tidak	Tidak	Read-only
Tambah transaksi	transactions	Ya	Ya	Tidak/Ya*	Tidak	Create
Edit transaksi	transactions	Ya	Tidak	Ya	Tidak	Update
Hapus transaksi	transactions	Ya*	Tidak	Tidak	Ya*	Hanya jika fitur memang ada

*** Contoh; mahasiswa harus menyesuaikan dengan fitur PBL sebenarnya.**
Gunakan DB Latihan individu jika DB pada PBL dianggap kredensial.

Terapkan least privilege

Jika aplikasi latihan hanya perlu SELECT, INSERT, dan UPDATE pada kb_p4, berikan hanya tiga privilege tersebut. Jika DELETE tidak digunakan, jangan berikan DELETE. Runtime account juga tidak memerlukan CREATE, DROP, ALTER, GRANT OPTION, atau privilege administratif.

```
GRANT SELECT, INSERT, UPDATE

ON kb_p4.*

TO 'laravel_app'@'localhost’;
```

Lakukan verifikasi:

```
SHOW GRANTS FOR 'laravel_app'@'localhost';
```

Konfigurasi Laravel, pada file env akan berisi konsep seperti berikut:

DB_CONNECTION=mysql

DB_HOST=127.0.0.1

DB_PORT=3306

DB_DATABASE=kb_p4

DB_USERNAME=laravel_app

DB_PASSWORD=<secret_yang_disimpan_aman>

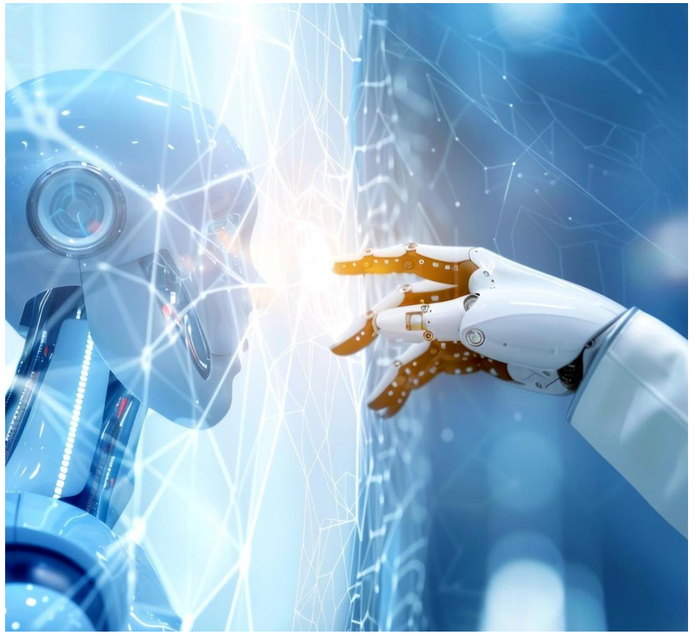
Lakukan pengujian allowed dan forbidden (Individu dan Tim)

Test ID	Account	Operasi	Expected	Actual	Bukti
T01	p4_reader	SELECT	Allowed	...	Screenshot/ output
T02	p4_reader	INSERT	Forbidden	...	Error denied
T03	p4_reader	UPDATE	Forbidden	...	Error denied
T04	p4_operator	SELECT	Allowed	...	Screenshot/ output
T05	p4_operator	INSERT	Allowed	...	Row bertambah
T06	p4_operator	UPDATE sebelum REVOKE	Allowed	...	Data berubah
T07	p4_operator	DELETE	Forbidden	...	Error denied
T08	p4_operator	CREATE TABLE	Forbidden	...	Error denied
T09	p4_operator	UPDATE sesudah REVOKE	Forbidden	...	Error denied
T10	laravel_app	Operasi sesuai matrix	Allowed	...	Evidence
T11	laravel_app	Operasi di luar matrix	Forbidden	...	Evidence

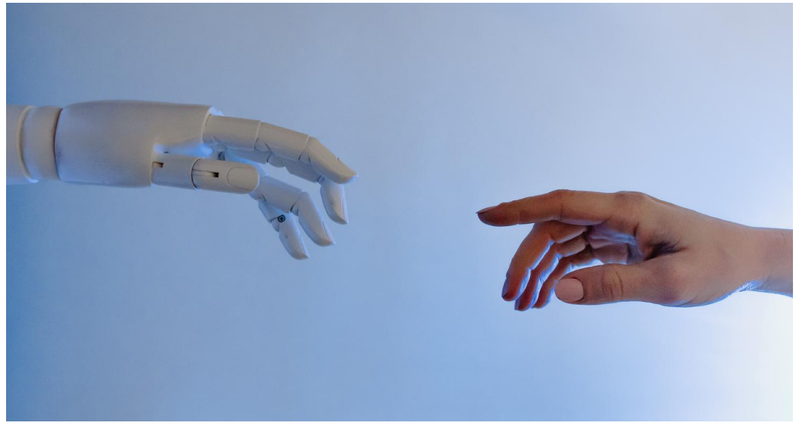
Tugas Laporan Praktikum

- Tetap gunakan sistematika penulisan tugas di e-learning.
- Isian (Bab 1 Latihan Individu, Bab 2 Latihan Tim, Bab 3 Kesimpulan):
  - Hasil latihan individu.
  - Setiap langkah, cantumkan screenshot query dan results serta keterangan setiap gambar. Jika ada temuan error (bukan disebabkan human errors), jangan diperbaiki, jadikan sebagai **evidence,** dan terjemahkan maksud dari error / warning tersebut.
  - Hasil latihan tim (gunakan clone DB dari PBL)
  - Ringkasan Deskripsi topik PBL
  - Setiap langkah cantumkan screenshot query, results, serta keterangan setiap gambar dengan mencantumkan **siapa yang mengerjakan pada langkah tersebut**. Jika ada temuan error (bukan disebabkan human errors), jangan diperbaiki, jadikan sebagai **evidence,** dan terjemahkan maksud dari error / warning tersebut.
  - Kesimpulan (pengujian allowed dan forbidden pada Latihan Individu dan Tim, dan beri keterangan)
  - Dokumentasi tim pengerjaan

Thank you for your attention



Any questions?







TRPL
PROGRAM STUDI
TEKNOLOGI REKAYASA PERANGKAT LUNAK
POLIBATAM